

UNIVERSIDADE DE MOGI DAS CRUZES
BACHARELADO EM ENGENHARIA DE SOFTWARE

BRUNO HIDEO SILVA SHIRAISHI
DIEGO ALVES DA SILVA FAGUNDES
GUSTAVO QUINTILIANO ERNESTO DOS SANTOS
PIETRO LOPES NOZELLA SOUSA

FALLSENSE
RELATÓRIO TÉCNICO DE AUDITORIA DE SEGURANÇA

MOGI DAS CRUZES - SP

2026

BRUNO HIDEO SILVA SHIRAISHI

DIEGO ALVES DA SILVA FAGUNDES

GUSTAVO QUINTILIANO ERNESTO DOS SANTOS

PIETRO LOPES NOZELLA SOUSA

FALLSENSE

RELATÓRIO TÉCNICO DE AUDITORIA DE SEGURANÇA

Documentação apresentada para o Prof. Fabiano Bezerra Menegidio sobre o projeto relacionado à disciplina de Políticas de segurança da informação do curso de Bacharelado em Engenharia de Software.

MOGI DAS CRUZES - SP

2026

RESUMO

Este relatório documenta os resultados do teste de invasão (Penetration Test) aplicado à API e ao frontend da plataforma FallSense, um ecossistema de monitoramento de saúde. O trabalho seguiu o padrão internacional Penetration Testing Execution Standard (PTES) e empregou as classificações do OWASP API Security Top 10 (2023), OWASP Web Top 10 (2021) e do NIST SP 800-115. A avaliação combinou abordagens black-box e gray-box, com foco nos mecanismos de autenticação, controle de acesso, validação de entradas e gerenciamento de recursos. Os resultados demonstraram maturidade arquitetural na prevenção de injeções e na proteção criptográfica, porém revelaram vulnerabilidades de severidade Média relacionadas à lógica de negócio (enumeração de usuários e ausência de limitação de taxa) e à configuração de proxies (falsificação de IP). O documento apresenta a matriz de riscos baseada no CVSS v3.1 e propõe mitigações específicas no código-fonte, elevando a segurança do sistema para padrões de produção.

Palavras-chave: Pentest. PTES. OWASP. API Security. FallSense. CVSS.

ABSTRACT

This report documents the results of the penetration test applied to the API and frontend of the FallSense platform, a health monitoring ecosystem. The work followed the international Penetration Testing Execution Standard (PTES) and employed the classifications of the OWASP API Security Top 10 (2023), OWASP Web Top 10 (2021), and NIST SP 800-115. The assessment combined black-box and gray-box approaches, focusing on authentication mechanisms, access control, input validation, and resource management. The results demonstrated architectural maturity in preventing injections and in cryptographic protection; however, they revealed Medium-severity vulnerabilities related to business logic (user enumeration and lack of rate limiting) and proxy configuration (IP spoofing). The document presents the risk matrix based on CVSS v3.1 and proposes specific source-code mitigations, elevating the system's security to production standards.

Keywords: Pentest. PTES. OWASP. API Security. FallSense. CVSS.

SUMÁRIO

1. introdução.....	7
2. FASE 1 – PRÉ-ENGAJAMENTO	8
2.1 Escopo autorizado.....	8
2.2 Restrições e regras de engajamento	8
2.3 Ferramentas e ambiente	8
3. FASE 2 – COLETA DE INFORMAÇÕES.....	9
3.1 Informações obtidas passivamente	9
3.2 Enumeração ativa de serviços.....	9
4. FASE 3 – MODELAGEM DE AMEAÇAS.....	10
4.1 Ativos críticos	10
4.2 Atores de ameaça	10
4.3 Cenários de ataque modelados	10
5. FASE 4 – ANÁLISE DE VULNERABILIDADES	11
5.1 Identificação preliminar de fragilidades	11
5.2 Ferramentas de apoio	11
6. FASE 5 – EXPLORAÇÃO.....	12
6.1 Enumeração de usuários (OWASP API 2:2023).....	12
6.2 Ausência de rate limiting na recuperação de senha (OWASP API 4:2023)	12
6.3 Falsificação de IP (OWASP Web A05:2021)	12
6.4 Defesas bem-sucedidas.....	13
6.5 XSS armazenado – exploração parcial	13
7. FASE 6 – PÓS-EXPLORAÇÃO.....	14
7.1 Impactos operacionais e de negócio	14
7.2 Limitações do teste	14
8. FASE 7 – RELATÓRIO E RECOMENDAÇÕES	15
8.1 Matriz de riscos (CVSS v3.1)	15

8.2 Plano de remediação	15
8.2.1 Padronização Da Resposta De Recuperação De Senha.	16
8.2.2 Implementação De Rate Limiting.....	16
8.2.3 Configuração De Trusted Proxies No Uvicorn.....	16
8.2.4 Sanitização De Saída	16
9. CONCLUSÃO	17
REFERÊNCIAS	18

1. INTRODUÇÃO

A plataforma FallSense foi desenvolvida para monitorar dados de saúde de pessoas idosas, armazenando informações sensíveis e realizando comunicação em tempo real entre cuidadores e familiares. Por lidar com dados pessoais e exigir alta disponibilidade, o sistema deve atender a requisitos rigorosos de confidencialidade, integridade e conformidade com a Lei Geral de Proteção de Dados (LGPD). Este relatório descreve a auditoria de segurança ofensiva (Penetration Test) executada sobre a API backend (FastAPI/Uvicorn, hospedada no Render com proxy Cloudflare) e o frontend (Flutter Web). Todo o processo foi conduzido sob a metodologia PTES, com o intuito de oferecer uma visão completa e baseada em evidências sobre a resiliência do sistema. O objetivo primário foi identificar, explorar e medir o impacto de vulnerabilidades reais, fornecendo ao final um plano de ação para correção. O documento está organizado exatamente conforme as sete fases do PTES, garantindo rastreabilidade entre a metodologia e os achados técnicos.

2. FASE 1 – PRÉ-ENGAJAMENTO

A fase de pré-engajamento estabeleceu as bases contratuais e técnicas da auditoria, alinhando expectativas entre o executor e os responsáveis pelo FallSense.

2.1 ESCOPO AUTORIZADO

- Ativos a testar: Backend: <https://fallsense-api.onrender.com> (API RESTful)
Frontend: Cliente Flutter Web (acessível via localhost e posteriormente integrado)
- Credenciais fornecidas: Usuário limitado: `usuario_teste@fallsense.com`
Nenhuma conta administrativa foi disponibilizada (testes de escalação baseados em privilégios mínimos).
- Nível de conhecimento: Black-box para o atacante externo, migrando para gray-box após acesso autenticado.

2.2 RESTRIÇÕES E REGRAS DE ENGAJAMENTO

- Ficam excluídos ataques de Negação de Serviço Distribuída (DDoS) volumétrica.
- Testes de rate limit são permitidos de forma manual e em baixa frequência, para não exceder cotas de serviços terceirizados (API Brevo).
- Nenhum dado real de usuários foi manipulado; a base de testes é controlada. • A exploração não poderia causar indisponibilidade permanente do backend.

2.3 FERRAMENTAS E AMBIENTE

- Burp Suite Professional (proxy interceptador)
- cURL (envio de requisições HTTP)
- Kali Linux 2026.1 (ambiente de testes)
- Postman (validação de endpoints)

3. FASE 2 – COLETA DE INFORMAÇÕES

Nesta fase, realizou-se o mapeamento passivo e ativo da superfície de ataque, sem exploração de vulnerabilidades.

3.1 INFORMAÇÕES OBTIDAS PASSIVAMENTE

- Domínio principal: fallsense-api.onrender.com – serviço Platform as a Service (Render).
- Uso de CDN Cloudflare (identificado pelos cabeçalhos cf-ray e server: cloudflare).
- Certificado SSL emitido para o domínio, com cadeia de confiança válida.
- Nenhuma informação sensível exposta em fóruns, repositórios públicos ou metadados de páginas.

3.2 ENUMERAÇÃO ATIVA DE SERVIÇOS

- Servidor HTTP: Uvicorn (ASGI para Python) – versão deduzida por comportamento de erros.
- Framework: FastAPI (evidenciado pelo padrão de respostas de validação, com detalhamento de campos e erros 422 Unprocessable Entity).
- Autenticação: JSON Web Token (JWT) – algoritmo HS256, validado a partir do cabeçalho de resposta que incluía Bearer.
- Endpoints expostos descobertos:
 - o POST /auth/login
 - o POST /auth/esqueci-senha
 - o GET /auth/me (requer autenticação)
 - o PATCH /auth/me (atualização de perfil)
 - o GET /compliance/termos/download
- Banco de dados inferido: PostgreSQL, pelo uso de SQLAlchemy (inferido por padrões de erro).
- Serviço de e-mail: API Brevo (identificada pelos endpoints de callback e cabeçalhos de envio).

Todas as informações coletadas alimentaram diretamente a modelagem de ameaças.

4. FASE 3 – MODELAGEM DE AMEAÇAS

Com base na superfície de ataque mapeada, foram definidos os ativos críticos, os atores de ameaça e os cenários de ataque relevantes.

4.1 ATIVOS CRÍTICOS

- Dados de usuários: e-mails, nomes, perfis de monitorados (saúde).
- Tokens JWT: representam a sessão ativa do usuário.
- Cota e reputação da API Brevo: o envio de e-mails transacionais tem custo financeiro e está sujeito a bloqueios por abuso.
- Integridade dos logs: registros de auditoria para conformidade LGPD.

4.2 ATORES DE AMEAÇA

- Atacante externo não autenticado: sem credenciais, podendo automatizar requisições e testar listas de e-mails.
- Usuário interno mal-intencionado: com credenciais de baixo privilégio, visando escalção, injeção de código ou acesso não autorizado a dados de terceiros.

4.3 CENÁRIOS DE ATAQUE MODELADOS

1. Quebra de autenticação via confusão de algoritmo JWT (OWASP API 2:2023).
2. Enumeração de contas válidas por diferenciação de respostas na recuperação de senha (API 2).
3. Esgotamento de recursos (lack of resources) através da rota de reset sem limitação (API 4:2023).
4. Atribuição em massa para escalção de privilégios (API 6:2023).
5. Injeção de código malicioso (XSS armazenado) via campos de perfil (Web A03:2021).
6. Manipulação de cabeçalhos de proxy para falsificação de IP (Web A05:2021).

5. FASE 4 – ANÁLISE DE VULNERABILIDADES

Nesta etapa, cada cenário modelado foi inspecionado por meio de requisições controladas, buscando-se respostas anômalas, vazamentos de informação e falhas de lógica, sem ainda confirmar o impacto total (exploração real reservada à Fase 5)

5.1 IDENTIFICAÇÃO PRELIMINAR DE FRAGILIDADES

- Recuperação de senha: as respostas para e-mail válido e inválido diferem em tamanho e conteúdo → possível vazamento de existência de conta.
- Envio repetitivo para recuperação de senha: o sistema aceitou múltiplas requisições seguidas sem retornar código de erro → suspeita de ausência de rate limiting.
- Cabeçalhos de IP: a aplicação processou requisições com X-ForwardedFor e True-Client-IP forjados, sem rejeição → possível falha de configuração de trusted proxies.
- Atualização de perfil com campos extras: o backend aceitou is_admin, role, mas os descartou → defesa aparente contra mass assignment.
- JWT adulterado: a API rejeitou tokens sem assinatura → resistência à confusão de algoritmo.

5.2 FERRAMENTAS DE APOIO

Todas as requisições foram manipuladas via Burp Suite, e as respostas analisadas quanto a códigos HTTP, headers e corpo. Nenhum scanner automático foi utilizado em larga escala, preservando a integridade do ambiente de teste.

6. FASE 5 – EXPLORAÇÃO

6.1 ENUMERAÇÃO DE USUÁRIOS (OWASP API 2:2023)

- Cenário: POST /auth/esqueci-senha
- Procedimento: Enviou-se o payload {"email":"usuario_teste@fallsense.com"} e, em seguida, {"email":"naoexiste@fallsense.com"}.
- Resultado: Para o e-mail válido, o servidor retornou HTTP 200 OK com {"mensagem":"E-mail enviado com sucesso!"} (42 bytes). Para o inexistente, o mesmo código, porém com {"mensagem":"Se o e-mail estiver cadastrado, o código será enviado."} (71 bytes).
- Impacto confirmado: A diferença de payload permite automatização de ataques de enumeração de contas, fornecendo a um atacante uma lista de e-mails válidos para ataques posteriores de força bruta ou phishing direcionado.

6.2 AUSÊNCIA DE RATE LIMITING NA RECUPERAÇÃO DE SENHA (OWASP API 4:2023)

- Cenário: POST /auth/esqueci-senha
- Procedimento: Dispararam-se 5 requisições para o mesmo e-mail, em um intervalo de 30 segundos.
- Resultado: Todas as requisições obtiveram HTTP 200 OK e, conforme logs do provedor, cada uma disparou um e-mail transacional via Brevo.
- Impacto confirmado: A falta de throttling permite que um atacante abuse da cota paga do serviço de e-mail, gere custos financeiros à operação e, eventualmente, leve a bloqueios por spam.

6.3 FALSIFICAÇÃO DE IP (OWASP WEB A05:2021)

- Cenário: Requisição GET /auth/me com cabeçalhos forjados.
- Procedimento: Foram injetados X-Forwarded-For: 127.0.0.1, XOriginating-IP: 127.0.0.1 e True-Client-IP: 127.0.0.1.
- Resultado: O servidor processou a requisição normalmente (HTTP 200 OK), refletindo o IP forjado nos logs da aplicação (constatado em console do Render).

- Impacto confirmado: Um atacante pode encobrir sua origem verdadeira, contaminar registros de auditoria e, potencialmente, contornar futuras regras de firewall baseadas em IP.

6.4 DEFESAS BEM-SUCEDIDAS

Todos os vetores listados a seguir foram submetidos a tentativas reais de exploração, sendo bloqueados com sucesso:

- Confusão de algoritmo JWT: Modificação do header para "alg":"none" e remoção da assinatura → HTTP 401 Unauthorized. O backend rejeitou o token antes de qualquer processamento.
- Acesso sem token: GET /auth/me sem cabeçalho Authorization → HTTP 422 (falta de campo obrigatório).
- Atribuição em massa: Injeção de is_admi, role, is_superuser via PATCH /auth/me → os campos foram ignorados e não persistiram no banco (verificado por nova consulta GET /auth/me).
- SQL Injection por formato de e-mail: Uso de ' no campo de login → HTTP 422 com mensagem de validação de formato, barrando o payload antes da camada de banco.

6.5 XSS ARMAZENADO – EXPLORAÇÃO PARCIAL

- Procedimento: PATCH /auth/me com {"nome_completo":""}.
• Resultado: O backend aceitou e armazenou a string (HTTP 200 OK), sem sanitização. Contudo, no frontend Flutter Web (renderização CanvasKit), o conteúdo foi exibido como texto literal, impedindo a execução do script.
- Confirmação: A vulnerabilidade existe na API (armazenamento inseguro), mas a superfície de ataque atual não permite exploração. Caso um novo cliente (ex.: painel HTML) consuma os mesmos dados, o XSS será explorável.

7. FASE 6 – PÓS-EXPLORAÇÃO

Após a exploração, foi analisada a profundidade do comprometimento possível, a escalabilidade dos ataques e o risco residual. Como o engajamento era focado em validação de controles, não houve tentativa de estabelecer persistência, pivotar para outros sistemas ou exfiltrar dados reais.

7.1 IMPACTOS OPERACIONAIS E DE NEGÓCIO

- **Custo financeiro:** A exploração do rate limiting poderia ser automatizada para consumir toda a cota do Brevo, gerando custos adicionais e potencial suspensão do serviço de e-mails.
- **Conformidade LGPD:** A falsificação de IP contamina os logs de acesso, dificultando a rastreabilidade de incidentes e podendo configurar não conformidade com os princípios de segurança e responsabilização.
- **Engenharia social e força bruta:** A lista de contas válidas obtida via enumeração habilita ataques futuros mais direcionados, aumentando a probabilidade de comprometimento de credenciais.
- **Risco de XSS futuro:** Embora mitigado no cliente atual, o armazenamento de payloads maliciosos é um passivo técnico que pode ser explorado se novas interfaces web forem acopladas.

7.2 LIMITAÇÕES DO TESTE

- Não foi realizado teste de estresse de rede.
- O acesso ao banco de dados e ao código-fonte não fez parte do escopo, limitando a análise de falhas de configuração interna.
- A exploração do XSS não pôde ser demonstrada em ambiente real de usuário final.

8. FASE 7 – RELATÓRIO E RECOMENDAÇÕES

Esta fase consolida os achados em uma matriz de riscos baseada no CVSS v3.1 e apresenta o plano de remediação final, cumprindo o objetivo de documentar e orientar a correção das vulnerabilidades.

8.1 MATRIZ DE RISCOS (CVSS V3.1)

ID	Vulnerabilidade	Categoria OWASP	Vetor de Ataque (CVSS)	Score CVSS	Severidade
01	Enumeração de usuários	API2:2023 – Broken Authentication	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	5.3	MÉDIA
02	Ausência de <i>rate limiting</i>	API4:2023 – Lack of Resources & Rate Limiting	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L	5.3	MÉDIA
03	Falsificação de IP (<i>Spoofing</i>)	Web A05:2021 – Security Misconfiguration	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N	5.3	MÉDIA
04	Armazenamento inseguro de XSS	Web A03:2021 – Injection	AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:N	5.4	MÉDIA
05	Atribuição em massa (escalação)	API6:2023 – Mass Assignment	N/A (protegido)	0.0	INFORM ATIVO
06	Confusão de algoritmo JWT	API2:2023 – Broken Authentication	N/A (protegido)	0.0	INFORM ATIVO

Figura 1 – Matriz de riscos

Nota: O CVSS do XSS reflete o risco hipotético caso uma interface HTML pura venha a consumir a API. No cenário atual, a exploração é inviabilizada pelo frontend Flutter.

8.2 PLANO DE REMEDIAÇÃO

As correções propostas devem ser implementadas no código-fonte do backend e na configuração do servidor.

8.2.1 Padronização Da Resposta De Recuperação De Senha

Unificar a mensagem, independentemente da existência do e-mail, eliminando a diferença de tamanho e conteúdo.

8.2.2 Implementação De Rate Limiting

Inserir uma verificação temporal baseada na última solicitação de recuperação de senha para o usuário. Bloquear novas requisições por um intervalo mínimo (ex.: 120 segundos).

8.2.3 Configuração De Trusted Proxies No Uvicorn

Restringir a confiança em cabeçalhos de encaminhamento apenas aos IPs da CDN Cloudflare e à rede interna.

8.2.4 Sanitização De Saída

Utilizar bleach ou função equivalente para remover tags HTML nos campos de texto livre, prevenindo XSS independentemente do cliente consumidor.

9. CONCLUSÃO

A auditoria de segurança do FallSense, conduzida sob a disciplina do PTES, comprovou a solidez das camadas de validação de entrada e de proteção criptográfica, mérito do uso adequado de frameworks modernos como FastAPI e Pydantic. As vulnerabilidades encontradas são de severidade Média e residem exclusivamente na lógica de negócio e na configuração de infraestrutura. A aplicação das quatro recomendações propostas eliminará os riscos identificados, garantirá conformidade com a LGPD no que tange à rastreabilidade e à proteção de dados, e posicionará a plataforma para uma operação segura no sensível domínio da saúde digital. O presente relatório encerra o ciclo do PTES, fornecendo à equipe de desenvolvimento todas as evidências e orientações necessárias para a remediação e a evolução contínua da segurança do sistema.

REFERÊNCIAS

OWASP. API Security Top 10 2023. Disponível em:

<https://owasp.org/APISecurity/editions/2023/en/0x00-header/> . Acesso em: 19 maio 2026.

OWASP. OWASP Top 10 Web Application Security Risks – 2021. Disponível em:

<https://owasp.org/www-project-top-ten/> . Acesso em: 19 maio 2026.

PENETRATION TESTING EXECUTION STANDARD. PTES Technical Guidelines.

Disponível em: <http://www.pentest-standard.org/> . Acesso em: 18 maio 2026.

NIST. Technical Guide to Information Security Testing and Assessment (NIST SP

800-115). Disponível em: <https://csrc.nist.gov/publications/detail/sp/800-115/final> .

Acesso em: 18 maio 2026.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados (LGPD). Diário Oficial da União, Brasília, 2018.